SECURITY OPERATIONS / IMPLEMENTATION GUIDE

Sentinel Stack

What is live, how the local prototype works, what was built, and what remains unconnected.

LIVE PUBLIC PREVIEW	LOCAL PROTOTYPE	SECURITY POSTURE
GitHub Pages site; static public snapshot; HTTPS enforced.	Node.js read-only console bound to loopback; separate from public site.	Inventory and audit views only. No active firewall, scanning, or production protection.

The important distinction

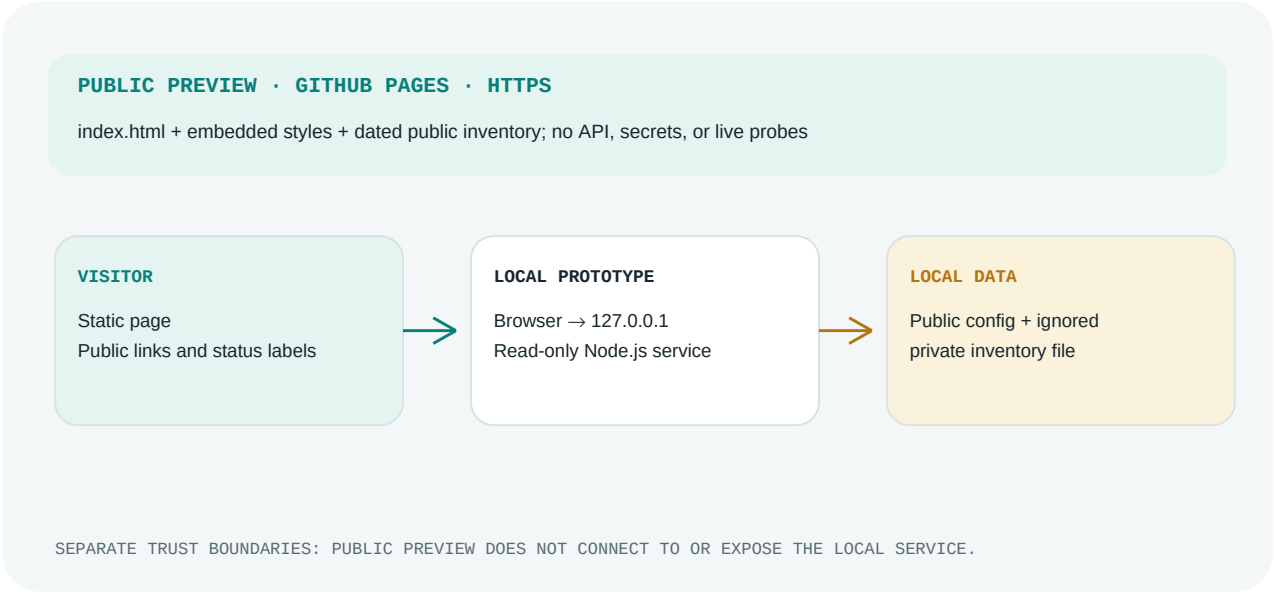
The website is a public, read-only **design and inventory preview**. It does not monitor production or protect applications. The fuller Node.js prototype runs locally and contains guarded utilities for inventory sync and manual HTTPS checks, but provider integrations and scanners are not connected. The two surfaces are kept separate so the public page cannot reach local private inventory.

Prepared 18 October 2026 · Version 0.1 · Project status: prototype

01 / SYSTEM MAP

Two surfaces, two trust boundaries

The public dashboard is deliberately static. The local console reads configuration and local snapshot files through a loopback-only API. No request path connects the public site to the local service.



SURFACE	WHAT IT DOES	WHAT IT DOES NOT DO
Public GitHub Pages preview	Renders a dated inventory of public repositories and one public collaboration; shows audit evidence and verification gaps.	No API calls, monitoring, private records, credentials, or security enforcement.
Local Node.js console	Serves dashboard pages and read-only JSON on 127.0.0.1; merges the public inventory with a locally ignored private repository file when present.	No remote listener, write API, telemetry, or automatic remediation.
Local utilities	Optional GitHub inventory sync, watcher, and reviewed HTTPS/TLS endpoint probe.	No continuous uptime schedule unless the owner runs a local process; no load or WAF checks.

Public deployment

Repository: github.com/AyushKJha/sentinel-stack
Live preview: ayushkjha.github.io/sentinel-stack
The GitHub Pages page requires HTTPS and serves a public-only static snapshot. The local data file containing private repository names is not included in the public repository.

02 / WHAT WAS BUILT

Implementation inventory

AREA	IMPLEMENTED	CURRENT STATE
Security operations UI	Dark SOC-style layout; posture cards; exposure bar; prioritized verification gaps; public asset register; responsive layout.	Live as a static GitHub Pages preview.
Public inventory	A dated list of 16 public repositories and one separately labeled partner collaboration, with registered live addresses where known.	Snapshot only; new repositories do not auto-appear on the public site.
Local server	Node HTTP server serves the UI and read-only /api/overview and /api/health routes. Requests must use the expected loopback Host header.	Local only; no authentication needed while it stays on loopback.
Safe endpoint probe	Allow-list-based HTTPS checker with DNS/IP safety checks, fixed port rules, timeouts, and no redirects; stores status, timing, and TLS expiry.	Manual run only; use reviewed targets in config/targets.json.
GitHub inventory tools	Explicit sync and optional 15-minute watcher use a temporary read-only token and keep private inventory in an ignored local file.	Not a GitHub App; token is not persisted by the scripts.
Tests	Four Node tests cover allow-list enforcement, local/private address rejection, and response security headers.	Latest local run: 4 passed, 0 failed.

What changed in the design

The original portfolio-like hero was refocused into an attack-surface console. The redesign adds a network-map motif, security status colors, an asset exposure split, a verification queue, compact technical labels, and clear snapshot-only warnings. The public dashboard uses static markup so it can be hosted on GitHub Pages without a server or secrets.

03 / HOW DATA FLOWS

Request and monitoring flow

On the public page, the browser downloads HTML and CSS from GitHub Pages. Repository rows and status text are part of that page. The browser does not call Sentinel APIs or probe the registered services.

In the local prototype, the browser requests /api/overview. The server reads config/repos.json, config/providers.json, data/snapshot.json, config/releases.json, and, if it exists, data/private-repos.local.json. It returns that assembled view without writing any data.

Manual HTTPS check flow

STEP	CHECK
1. Review	An operator adds an HTTPS endpoint to config/targets.json and confirms that the domain is under their control.
2. Resolve	The checker resolves DNS and rejects private, loopback, link-local, or otherwise unsafe destinations.
3. Probe	It sends a bounded request only to an allow-listed host on the permitted HTTPS port. It does not follow redirects or retain response bodies.
4. Record	It records response status, timing, and TLS certificate expiry in local health data. These results are not streamed to GitHub Pages.

Optional GitHub inventory flow

The sync script reads a short-lived read-only token from GITHUB_READ_TOKEN, fetches repository metadata, and writes private repository metadata only to data/private-repos.local.json. The watcher repeats discovery while the machine and process are running and prints newly discovered entries for review. A new repository is not automatically trusted as a monitoring target; URLs and probe targets still require review.

Local AI is an optional design direction only. No model endpoint is connected in the current build, and no AI output can execute commands or change infrastructure.

04 / SECURITY AND LIMITS

Controls are not assumed

CONTROL AREA	STATUS	EVIDENCE / LIMIT
Public page isolation	Implemented	Static GitHub Pages assets only; public-only data; no connection to the local service.
Local API exposure	Constrained	Binds to 127.0.0.1, checks Host header, sets browser security headers, and provides GET/HEAD only.
Endpoint reachability	Manual tool	Safe HTTPS allow-list probe exists. Live probes were not run as part of the public preview.
GitHub branch rules and secret scanning	Unverified	An authorized provider connection is required to read current settings.
Source/dependency/APK scanners	Not connected	Gitleaks, Trivy, Semgrep and MobSF are planned local integrations; none are installed or run by this prototype.
Traffic, load, firewall/WAF, backups	Not connected	No provider telemetry or load test exists. The dashboard itself does not add these protections.
Private repo data	Local-only	Stored in the ignored data/private-repos.local.json file; not part of the static public preview.

DO NOT TREAT THE DASHBOARD AS A FIREWALL, WAF, AUTHENTICATION LAYER, LOAD BALANCER, BACKUP SYSTEM, OR PROOF THAT A PROJECT IS SECURE.

Audit evidence snapshot

The October 17, 2026 audit checked 176 local README links (all resolved) and 33 distinct external links (all responded at the time of checking). Three local suites passed completely; two were partial because of missing optional dependencies or sandbox restrictions. Production load tests, disaster recovery restore tests, and a full historical secret scan were not performed. These are historical results, not current live health readings.

05 / RUN AND NEXT

Operate the local prototype

The public page is a static preview; the fuller prototype is run from its local project folder. It requires Node.js 22.13 or newer and no installed npm packages for the core dashboard.

START

PowerShell: cd sentinel-stack
node src/server.mjs

Open the loopback URL printed by the process. The server selects a free port and stays bound to 127.0.0.1. Stop it with Ctrl+C.

VERIFY

Run node --test. The current test set covers HTTPS target allow-listing, rejection of local/private destinations, and browser security headers. The endpoint checker is optional and must only be run against reviewed targets.

OPTIONAL INVENTORY SYNC

Set GITHUB_READ_TOKEN only in the current PowerShell session, run node scripts/sync-github.mjs, then remove the environment variable. Use a fine-grained read-only token. Do not paste it into source files, logs, or the public site.

Recommended next stages

STAGE	NEXT WORK
Measure	Connect read-only GitHub security posture, reviewed hosting metrics, and scheduled endpoint checks with bounded concurrency.
Protect	Enable and verify repo rules, secret push protection, dependency alerts, per-host WAF/rate limits, authentication, and tested backups.
Prove	Define user journeys and capacity targets; load-test staging; record p95 latency, errors, resource use, and restore outcomes.
Assist	Only after measured feeds exist, add optional local AI summaries of sanitized evidence. Keep recommendations advisory and human-reviewed.

Live public preview: ayushkjha.github.io/sentinel-stack
Source repository: github.com/AyushKJha/sentinel-stack

This guide distinguishes implemented behavior from the roadmap. A capability marked unverified, manual, or not connected should not be read as active monitoring or security coverage.